Politica di sicurezza

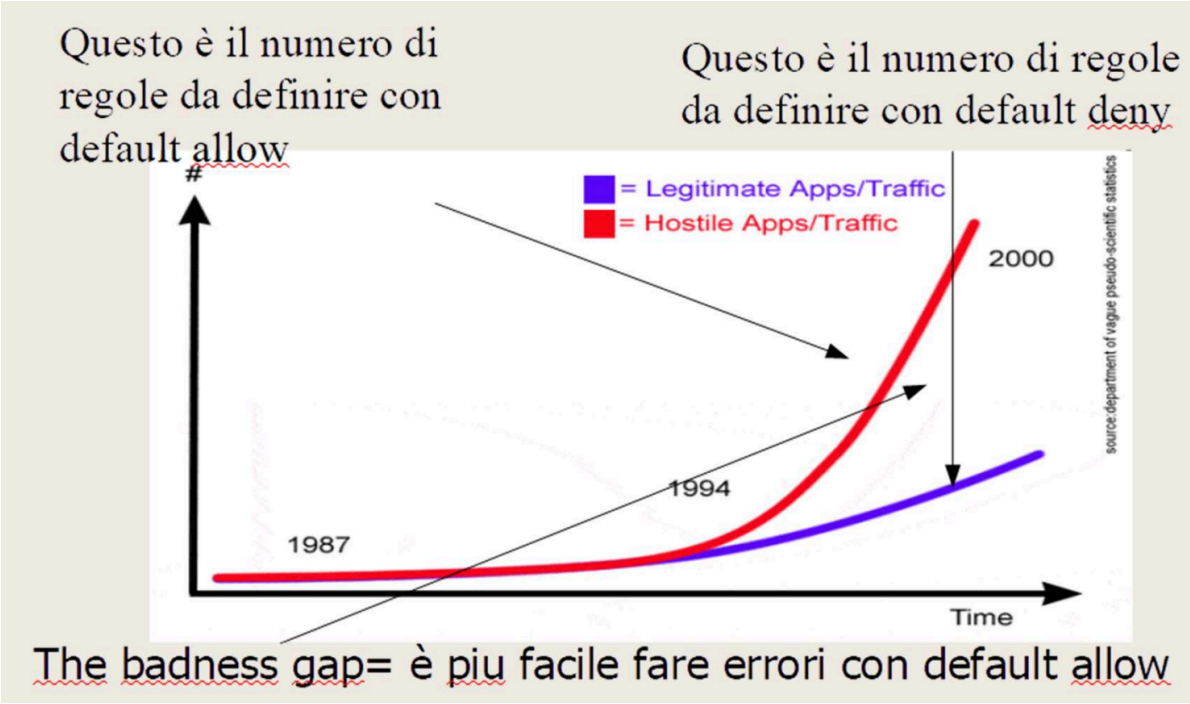
Description

Un insieme di regole definite dal proprietario del sistema o del processo aziendale che usa il sistema per decidere gli utenti che possono invocare una operazione e quando possono farlo

Esistono diverse categorie di politiche descrivibili come il risultato di due scelte indipendenti (ortogonali)

Prima scelta (come si descrive)

- *Default allow:* la politica definisce le operazioni vietate
- *Default deny:* la politica definisce le operazioni permesse



Seconda scelta (vincoli su proprietario del sistema)

- *Discretionary Access Control:* decide il proprietario, tipica politica del mondo commerciale
- *Mandatory Access Control:* Esistono vincoli globali a tutto il sistema che nemmeno il proprietario può violare, tipica del mondo militare

Una definizione rigorosa della politica di sicurezza modella risorse condivise come ***oggetti*** ed utenti come ***soggetti*** che su di esse operano.

I soggetti invocano le operazioni definite dagli oggetti. Se un oggetto invoca le operazioni definite da altri oggetti allora diventa esso stesso un soggetto.

> 💡 Cosa sono oggetto e soggetto dipende dal livello di implementazione

Soggetto: utente, applicazione, programma, processo, thread, istruzione, microistruzione

Oggetto: tipo di dato astratto, procedura, parametro, risorsa logica, risorsa fisica

Discretionary Access Control

Per ogni oggetto esiste un proprietario che può essere quello del:

- *sistema informativo*
- *processo aziendale che definisce ed usa oggetto*

Il proprietario decide i diritti dei vari soggetti sui suoi oggetti e non ci sono vincoli sul proprietario (Tipico del mondo industriale/terziario/servizi)

Mandatory Access Control

Tutti gli utenti (soggetti) sono divisi in classi, tutte le risorse (oggetti) divise nelle stesse classi.

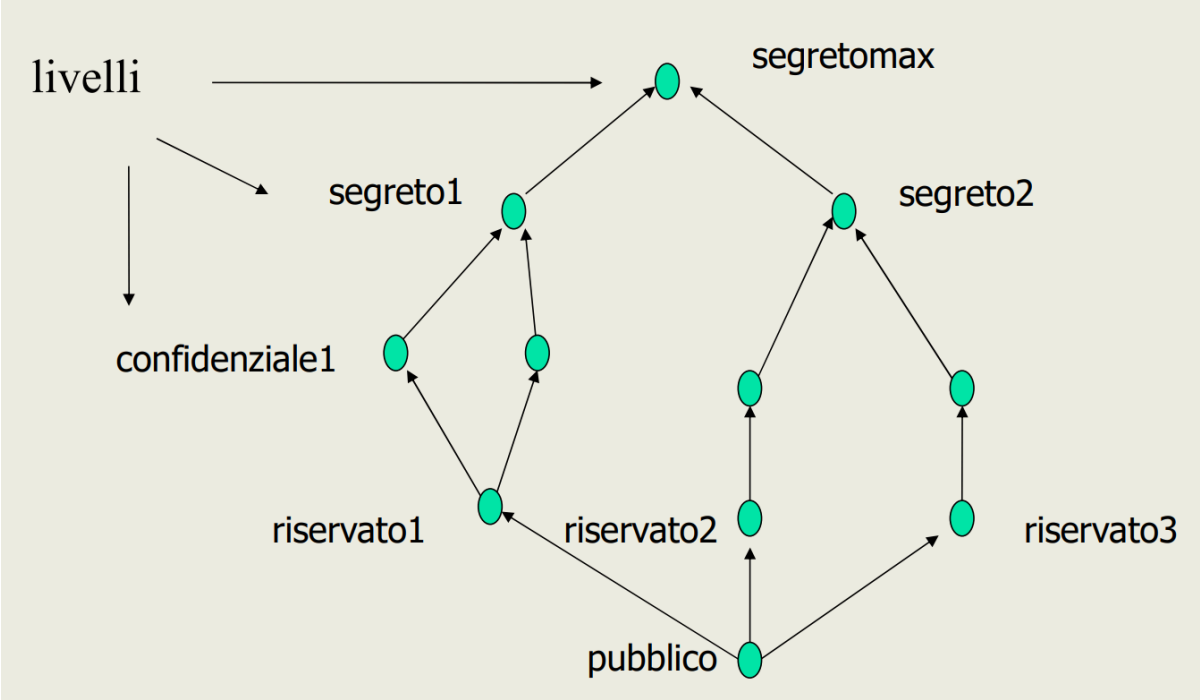
- Le classi sono ordinate parzialmente: livello di una classe non tutte le classi confrontabili
- Livello di un soggetto: quanto ci fidiamo
- Livello di un oggetto: quanto è importante

La possibilità di eseguire una certa operazione dipende:

- Dai livelli della classe del soggetto e di quella dell'oggetto
- Dall'owner che è però limitato dai livelli precedenti

Ordinamento Parziale

Non tutti i confronti sono definiti. Ad esempio tutte le informazioni segrete sono più importanti di tutte quelle riservate ma le classi di informazioni segrete e riservate non sono tra di loro confrontabili



Politica MAC / Information flow - No Write Down

No Write Down: privilegia la confidenzialità questa politica è tipica del mondo militare

Soggetto: Utente o programma utilizzato da utente
Oggetto = Risorsa = file
Operazioni: read/write/append

Un utente (soggetto/programma) può (ha il diritto di) leggere tutti i file che hanno classe minore o uguale alla sua, modificare i record dei file che hanno classe uguale alla sua e appendere un record ad un file che ha classe maggiore della sua.

È necessario anche il permesso dell' owner che può solo restringere ulteriormente non ampliare all'interno del dominio definito dalle regole owner (need to know)

Politica MAC / Information flow - No Write Up

No Write Up: privilegia l'integrità, tipica del controllo industriale, si vuole essere sicuri della bontà dei valori usati da un impianto nucleare anche a costo di rivelarli a terzi

Soggetto: Utente o programma utilizzato da utente
Oggetto = Risorsa = file
Operazioni: read/write/append

Un utente (soggetto/programma) può:
scrivere tutti i file di una classe minore o uguale alla sua, leggere tutti i file di una classe maggiore o uguale.
Un utente poco affidabile non può modificare dati critici

Chinese Wall

Gli oggetti del sistema sono partizionati in sottoinsiemi, l'utente che ha operato su un oggetto di un insieme non può operare su quelli in un altro insieme (nozione dinamica, tempo è influente)

- Permette di gestire conflitti di interesse
- E' dipendente dal tempo = politica dinamica mentre information flow è statica
- E' compatibile con MAC perché aggiunge vincoli

Mac statica

Una politica MAC statica ha il problema del trasferimento dell'informazione ai livelli alti, anche informazioni pubbliche hanno un livello di sicurezza elevato semplimente perché sono state prodotte da un soggetto con un livello elevato.

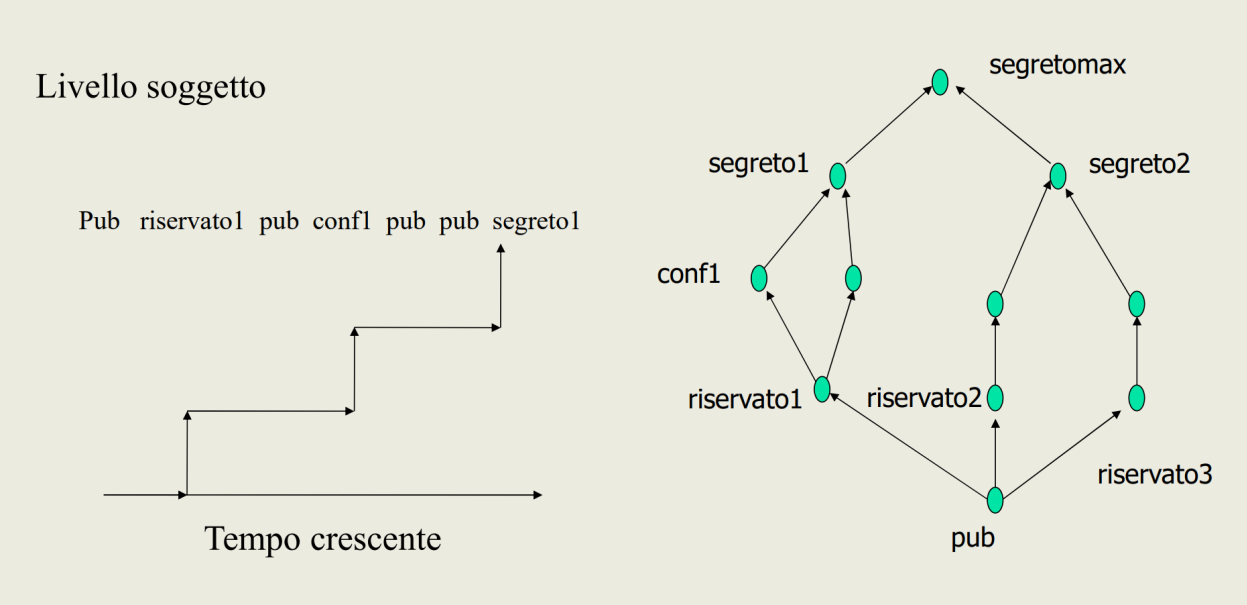
Questo trasferimento aumenta la complessità di gestione = non tutti possono leggere un informazione che è pubblica etc.

Si può rimediare mediante operazione di derubricazione (downgrade or declassify), la derubricazione riduce il livello delle informazioni per permettere accesso anche a soggetti di livello basso

Watermark

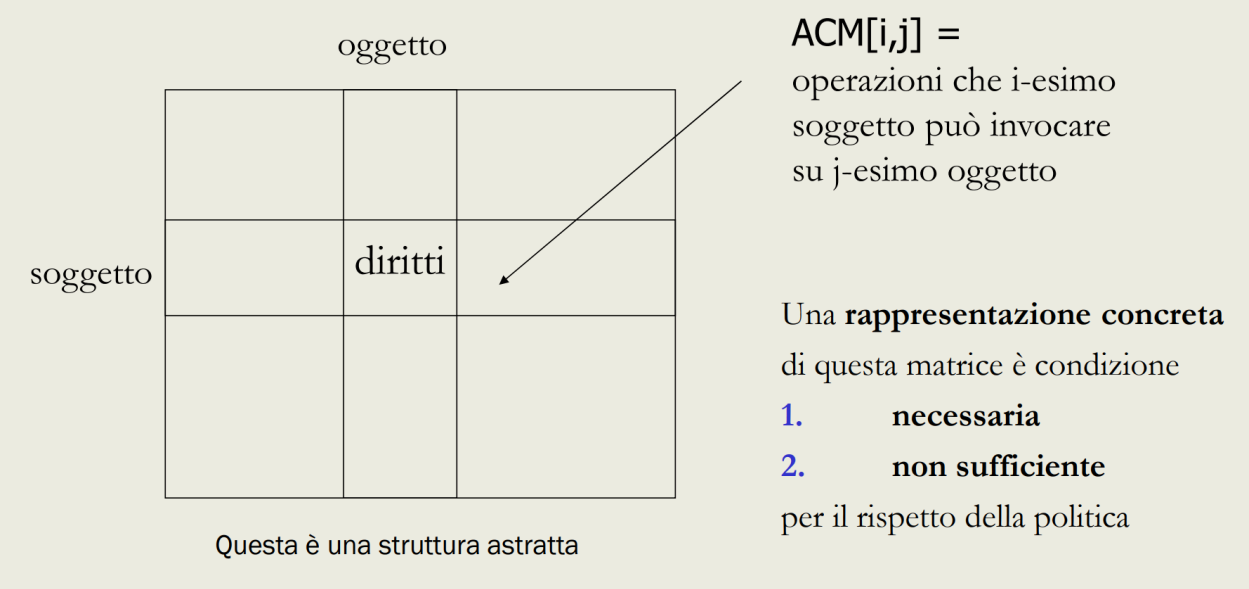
La politica adotta la nozione di livello ma il livello di un soggetto non è fissato ma varia in un certo range e dipende da quello degli oggetti su cui ha operato fino all'istante considerato.

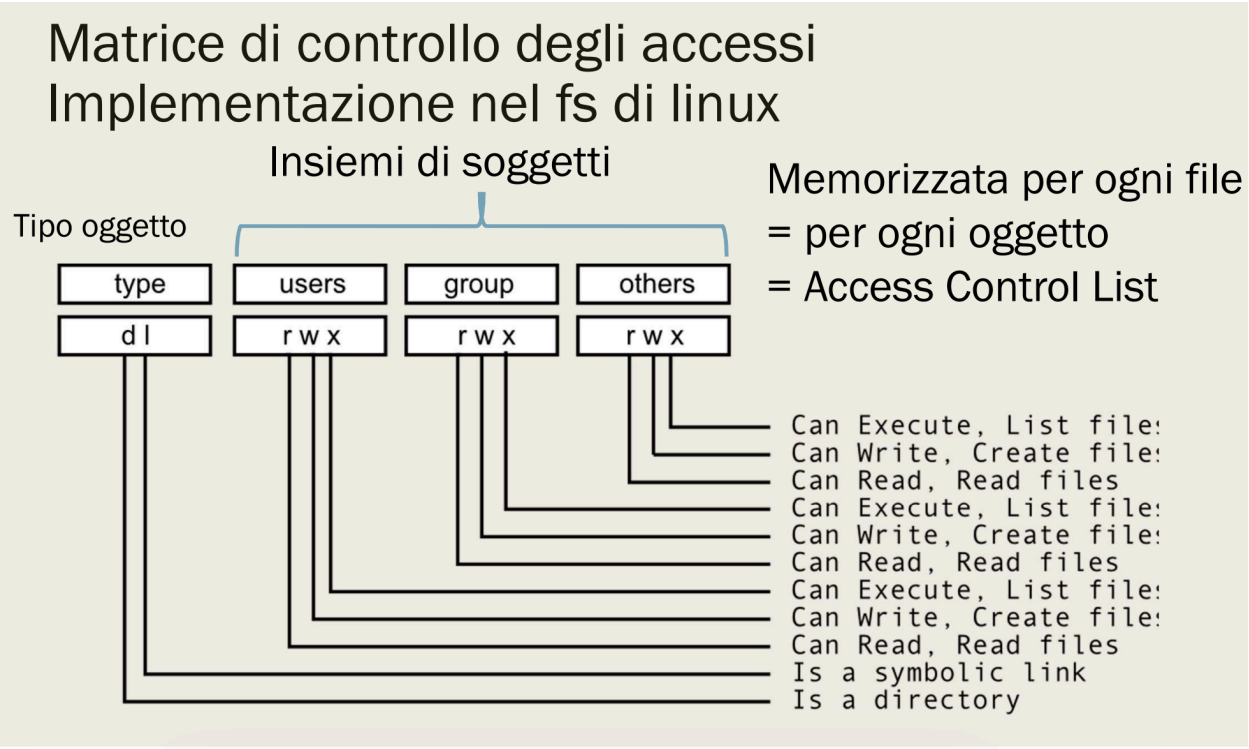
Ad esempio il livello di confidenzialità aumenta dopo che utente legge oggetti di livello elevato, ovviamente non diminuisce se dopo legge oggetti di livello minore.



Matrice di controlli degli accessi

Una struttura dati per rappresentare una politica di sicurezza





Trusted Computing Base

Insieme di tutti i componenti hardware, software e firmware di un sistema informatico che sono critici per la sua sicurezza. In altre parole, il ***TCB*** include

tutto ciò che è necessario per garantire il corretto funzionamento delle politiche di sicurezza del sistema.

Minore è il numero di componenti nel TCB, migliore è la situazione dal punto di vista della sicurezza informatica del sistema informatico considerato

Dimensione ridotta permette anche di utilizzare di dimostrare formalmente (con metodi matematici) la correttezza del TCB

La dimensione del TCB è un criterio che permette di confrontare strategie alternative di realizzare una stessa politica di sicurezza = le specifiche del TCB

Ogni decisione legata alla sicurezza richiede la risoluzione di 3 problemi:

1. Identificazione utente
2. Identificazione risorsa
3. Esame dei diritti

Autenticazione

Ha tre classi di metodi:

- **Una cosa che conosci:** password / PIN / nome del tuo cane/nome della squadra di calcio.
- **Una cosa che hai:** smart phone/carta di credito /token.
- **Una cosa che sei:** caratteristica biometrica
  - *Impronta digitale*
  - *Timbro vocale*
  - *Retina / Iride*

BIOMETRICS COMPARISON CHART

Biometric	Verify	ID	Accuracy	Reliability	Error Rate	Errors	False Pos.	False Neg.
Fingerprint	✓	✓	●●●●	▶▶▶	1 in 500+	dryness, dirt, age	Ext. Diff.	Ext. Diff.
Facial Recognition	✓	✗	●●●	▶▶	no data	lighting, age, glasses, hair	Difficult	Easy
Hand Geometry	✓	✗	●●●	▶▶	1 in 500	hand injury, age	Very Diff.	Medium
Speaker Recognition	✓	✗	●●	▶	1 in 50	noise, weather, colds	Medium	Easy
Iris Scan	✓	✓	●●●●	▶▶▶	1 in 131,000	poor lighting	Very Diff.	Very Diff.
Retinal Scan	✓	✓	●●●●	▶▶▶	1 in 10,000,000	glasses	Ext. Diff.	Ext. Diff.
Signature Recognition	✓	✗	●●	▶	1 in 50	changing signatures	Medium	Easy
Keystroke Recognition	✓	✗	●	▶	no data	hand injury, tiredness	Difficult	Easy
DNA	✓	✓	●●●●	▶▶▶	no data	none	Ext. Diff.	Ext. Diff.